CloudShield DevSecOps — AWS Reference Architecture

Flow: Source → Infrastructure as Code → Secure CI → Container Registry → Kubernetes Deployment → Monitoring

Developer Push to GitHub	**GitHub Actions** OIDC bootstrap workflow	**Terraform Bootstrap** VPC, subnets, NAT, S3 state, EC2 runner	**Self-hosted EC2 Runner** Terraform • Docker • SonarQube • Trivy • Grafana
CI Quality Gates Tests • SonarQube source analysis • Trivy filesystem scan	**Image Build & Scan** Docker build • Trivy HIGH/CRITICAL gate	**Amazon ECR** Immutable commit tags • scan-on-push	**Amazon EKS** Managed node group • Deployment • Service LoadBalancer
Monitoring Prometheus scrapes cluster/workload metrics	**Grafana** Dashboards for nodes, pods, CPU and memory	**Public endpoint** AWS load balancer for frontend	**Security controls** OIDC • Secrets Manager • IAM roles • non-root pod

Note: Reference implementation. EKS, NAT Gateway, EC2 and load balancers incur AWS charges. Use least-privilege IAM and restrict administrative access before production use.